

Compliance Audit

Compliance Audit is a formal review that checks whether an organization follows **required laws, regulations, standards, and internal policies**—especially those related to **cybersecurity and data protection**.

Cybersecurity Challenges for Organizations

- **Increasing Threat Landscape:**
 - Phishing, ransomware, insider threats, supply chain vulnerabilities
 - IoT and cloud adoption create broader attack surfaces
- **Regulatory Pressure:**
 - Must comply with GDPR, ISO 27001, SOX, HIPAA, etc.
- **Budget vs. Protection Gap:**
 - Limited resources vs. growing need for security investments
- **Human Factor Risks:**
 - Weak passwords, social engineering, lack of awareness

Compliance Basics

- **Purpose:**
 - Ensures an organization meets legal, ethical, and regulatory standards
 - Identifies risks, gaps, and areas for improvement
- **Benefits:**
 - Builds customer trust
 - Avoids legal penalties
 - Strengthens cyber resilience

Types of Security Audit

Type	Conducted By	Focus Area
Internal Audit	In-house team	Controls, policies, and procedures
External Audit	Third-party auditors	Independent verification
Compliance Audit	Regulatory or certifying body	Adherence to standards like ISO, NIST
Risk Audit	Security & risk analysts	Evaluate risk exposure and mitigation

Audit Decision Factors

- **Risk Impact:** How critical is the asset being audited?
- **Compliance Mandates:** Are there legal requirements (e.g. GDPR)?
- **Business Continuity Importance:** Is the system linked to vital operations?
- **Audit Scope & Resources:** Team availability, time constraints, data accessibility



Security Audit Phases

Phase	Description
Planning	Define scope, goals, roles
Scoping	List systems/assets and decide methodologies
Execution	Collect evidence, perform interviews, vulnerability scans
Reporting	Summarize findings, risk level, non-compliance issues
Remediation	Suggest corrective actions and improvements



Internal Audit Team Requirements

- **Skills Required:**
 - Understanding of IT systems, cybersecurity, governance frameworks
 - Audit procedures and forensic techniques
- **Traits:**
 - Integrity, independence, confidentiality, analytical mindset



Principles of Audits

- **Objectivity:** Unbiased assessments
- **Consistency:** Repeatable, reliable methods
- **Evidence-based:** Decisions backed by verifiable data
- **Transparency:** Clear documentation of findings
- **Risk-oriented:** Focused on most vulnerable areas



Auditor Personal Abilities

- **Hard Skills:**
 - Knowledge of frameworks: ISO, NIST, COBIT
 - Technical proficiency with audit tools (e.g., Nessus, SIEMs)
- **Soft Skills:**
 - Communication, critical thinking, diplomacy
 - Conflict resolution during sensitive assessments
- **Ethical Responsibility:**
 - Maintain privacy, avoid bias, report truthfully

Security Evaluation Overview

- **Purpose:** Assess the effectiveness of security controls and determine whether systems meet defined compliance and risk management standards.
- **Outcome:** Identifies vulnerabilities, rates security robustness, and validates trustworthiness of technologies or processes.

Evaluation Process

Step	Explanation
Define Security Target	Describe what is being evaluated (system, device, application)
Collect Evidence	Gather system documentation, test results, configuration files, and logs
Test Implementation	Conduct vulnerability scans, penetration testing, and behavioral analysis
Verify Against Standards	Match findings against benchmarks (ISO, NIST, etc.)
Document Findings	Compile reports and assign assurance levels

Evaluation Phases

Phase	Objective
Preparation	Define scope, target, evaluation environment
Analysis	Review security controls, access policies, configurations
Testing	Functional and non-functional testing (penetration, stress, compliance)
Reporting	Summarize vulnerabilities, risks, and compliance status
Remediation	Recommend and track fixes for identified issues

Assurance – 7 Evaluation Levels (Common Criteria – CC)

These levels indicate **trust depth and rigor** in security testing. The higher the level, the more thorough and formal the evaluation.

Level	Name	Evaluation Depth
EAL1	Functionally Tested	Basic checks; no developer assistance
EAL2	Structurally Tested	Analysis of design and configuration

Level	Name	Evaluation Depth
EAL3	Methodically Tested & Checked	Development support, methodical vulnerability scans
EAL4	Methodically Designed, Tested, Reviewed	Formal design documentation required
EAL5	Semi-Formally Designed & Tested	Rigorous process analysis, multiple environment testing
EAL6	Semi-Formal Verified Design	Advanced testing including simulations and formal proofs
EAL7	Formally Verified Design	Mathematical modeling, proofs, used for high-risk systems

💡 *Note:* Most commercial systems aim for **EAL2–EAL4**, while critical defense-grade systems target **EAL6–EAL7**.



Evaluation Methodology

◆ Key Components:

- **Security Target Document:** Defines scope and objectives
- **TOE (Target of Evaluation):** Actual asset or system under scrutiny
- **Protection Profile:** Abstract requirements expected from secure systems
- **Independent Testing:** External auditors simulate real-world scenarios

◆ Methods Used:

- Code review
- Configuration assessment
- Simulated attack scenarios
- Interview with stakeholders
- Comparative benchmarking



National Institute of Standards and Technology (NIST) Overview

◆ What is NIST?

- A **U.S. government agency** that creates cybersecurity frameworks to protect critical infrastructure.
- Famous for the **NIST Cybersecurity Framework (CSF)**—widely adopted across industries.

Components of the NIST Framework

Component	Purpose
Core	Defines security activities under five functions
Implementation Tiers	Show organization's cybersecurity maturity (Tier 1–4)
Profile	Tailored roadmap comparing current security state to target goals

The 4 NIST Implementation Tiers

Tier	Name	Description
Tier 1	Partial	Cybersecurity is ad hoc and reactive . No formal risk management processes.
Tier 2	Risk-Informed	Organization is aware of risks , but practices are inconsistent across departments.
Tier 3	Repeatable	Policies and procedures are established, documented, and regularly updated .
Tier 4	Adaptive	Cybersecurity is proactive and dynamic , with real-time threat response and continuous improvement.

 *Tip for exams:* Most organizations aim for **Tier 3** as a baseline, while **Tier 4** is ideal for critical infrastructure, finance, and healthcare sectors.

NIST Core Functions

1. **Identify** – Know your assets and risks
2. **Protect** – Implement safeguards (firewalls, access controls)
3. **Detect** – Monitor for threats and anomalies
4. **Respond** – Handle and mitigate incidents
5. **Recover** – Restore systems and data post-incident

Use of the NIST Framework

- **Risk Management:** Build proactive defense
- **Audit Preparation:** Aligns with security standards like ISO or GDPR
- **Security Roadmap:** Tracks progress and improves posture
- Used by **banks, cloud providers, government agencies**, and more

General Data Protection Regulation (GDPR)

Overview

What is GDPR?

- A **European privacy law** that protects personal data of EU citizens.
- Applies globally if your business handles EU data—even if you're not located in Europe.

Types of Privacy Data GDPR Protects

Type of Data	Examples
Identifiable Personal Info	Name, address, phone number
Sensitive Personal Info	Race, religion, biometric data
Online Identifiers	IP address, cookies, device data
Health & Financial Data	Medical records, banking info

Key Steps to Ensure GDPR Compliance

1. **Data Mapping:** Know what data you collect and where it's stored
2. **Consent Management:** Get clear opt-in permission; provide opt-out option
3. **Data Minimization:** Collect only what's necessary
4. **Right to Access/Erase:** Let users view/edit/delete their personal data
5. **Privacy by Design:** Build security into systems from the start
6. **Data Breach Notification:** Report breaches within 72 hours to authorities
7. **DPO Appointment (if required):** Assign a Data Protection Officer for oversight

 *Real-world tip:* Many organizations integrate **NIST CSF** for technical security, and **GDPR** for legal and privacy compliance—they complement each other beautifully.

International Organization for Standardization (ISO)

2700x Series

Overview

- A set of **global standards** jointly developed by **ISO** and **IEC**.
- Focus: **Information Security Management Systems (ISMS)**
- Key goal: Help organizations protect **confidentiality**, **integrity**, and **availability** of data.

Key Standards in the 2700x Family:

Standard	Purpose
ISO/IEC 27001	Specifies requirements for ISMS
ISO/IEC 27002	Code of practice for information security controls
ISO/IEC 27005	Guidelines for managing information security risk
ISO/IEC 27017	Security controls for cloud services
ISO/IEC 27018	Data privacy controls for cloud personal data

How the Standard Works

ISO/IEC 27001 Implementation Cycle (Plan–Do–Check–Act)

1. **Plan** – Define ISMS scope, policies, and risk assessment
2. **Do** – Implement security controls and train personnel
3. **Check** – Perform internal audits and reviews
4. **Act** – Take corrective actions and continuously improve

Certification Process

- Gap Analysis
- Internal Audit
- External Audit by Certification Body
- Issue of ISO 27001 Certificate

 *Fact:* ISO 27001 is **auditable**, meaning organizations can be officially certified.

History of ISO/IEC 27001

Timeline	Milestone
1995	Originates from British Standard BS 7799
2005	Formal release as ISO/IEC 27001:2005
2013	Updated version with new control structure and terminology
2022	Latest version: ISO/IEC 27001:2022 introducing improved Annex A

ISO/IEC 27001:2005 Domains

The 2005 version introduced **11 control domains**, each with multiple objectives and controls.

Domain	Focus Area
Security Policy	Management direction and objectives
Organization of Information Security	Internal responsibilities and coordination
Asset Management	Inventory and classification of assets
Human Resources Security	Pre, during, and post-employment practices
Physical and Environmental Security	Prevent unauthorized physical access
Communications & Operations Management	Network controls, malware protection
Access Control	User and system access management
Information Systems Acquisition, Dev & Maintenance	Secure development lifecycle
Information Security Incident Management	Detection and response to security breaches
Business Continuity Management	Disaster recovery and resilience
Compliance	Legal and regulatory requirements

Structure of ISO Standards

◆ Components of ISO 27001 Documentation:

Section	Description
Clause 4–10	Main clauses (Context, Leadership, Planning, Support...)
Annex A	List of controls categorized into 4 groups (114 total in 2005)
Control Objectives	Grouped within domains for evaluation
Statement of Applicability	Custom document listing applicable controls
Risk Treatment Plan	Outline of how identified risks will be mitigated

SOx Reports (Sarbanes-Oxley Act)

◆ Overview

- U.S. federal law passed in **2002** after corporate scandals (e.g., Enron, WorldCom).
- Ensures **transparency and accountability** in financial reporting and internal controls.

Key Sections:

Section	Purpose
302	Executives must certify the accuracy of financial reports
404	Requires assessment of internal controls over financial reporting
409	Mandates real-time disclosure of material changes

SOx Report Contents:

- Description of internal control framework used
- Identification of **control risks** and mitigation practices
- Auditor's independent opinion on control effectiveness
- Management's assessment report

SOC Reports – Auditor Process Overview

◆ **What are SOC Reports?**

- Developed by **AICPA (American Institute of CPAs)**
- Evaluate **controls in service organizations** that affect client data security and financial reporting

Types of SOC Reports:

Report	Focus Area	Audience
SOC 1	Internal controls over financial reporting (ICFR)	Auditors, financial stakeholders
SOC 2	Controls over security, availability, processing integrity, confidentiality, privacy	Clients and partners
SOC 3	Public summary of SOC 2 (for marketing/trust purposes)	General public

Auditor's Process:

1. **Planning & Scoping** – Define control objectives and coverage
2. **Evidence Collection** – Interviews, access logs, policy documents, system configs
3. **Testing Controls** – Check design & operational effectiveness
4. **Report Compilation** – Findings, exceptions, audit opinion
5. **Assurance Level Assignment** – Type I (design only) or Type II (design + effectiveness over time)

SOX Compliance and Security Controls

◆ IT Controls for SOX:

Control Type	Function
Access Controls	Ensure authorized personnel only access financial data
Change Management	Document and monitor system changes that affect reporting
Data Integrity Controls	Confirm accurate and unaltered financial records
Backup & Recovery	Protect against data loss in case of breach or disaster
Audit Trails & Logs	Track who did what, when, and where in the system

◆ Frameworks Often Used:

- **COSO**: Committee of Sponsoring Organizations of the Treadway Commission—used for internal control evaluation
- **COBIT**: For linking IT controls with business goals
- **ISO 27001**: For alignment with information security standards

💡 *Fact*: SOX compliance isn't just a finance function—it demands tight integration with IT and cybersecurity teams to safeguard the entire reporting ecosystem.

🧠 What Is COBIT?

COBIT stands for **Control Objectives for Information and Related Technologies**.

- Created by **ISACA** (Information Systems Audit and Control Association)
- Focuses on **governance and management of enterprise IT**
- Aligns IT practices with **business goals, risk management, compliance**, and performance

◆ Purpose:

- Improve **IT governance**
- Provide **control objectives** for audit and compliance
- Ensure **value delivery, risk mitigation**, and **resource optimization**

✚ COBIT Components

Component	Description
Framework	Core structure that links IT processes to business needs
Process Descriptions	Detailed guidance across 40+ processes within 5 domains
Control Objectives	Specific goals to ensure IT process integrity and performance

Component	Description
Management Guidelines	Help assign responsibilities, measure performance, and identify risks
Maturity Models	Evaluate process capabilities on a scale (0–5)
Performance Metrics (KPIs)	Quantify how well IT processes align with objectives
Goals Cascade	Maps stakeholder needs to IT-related goals and enablers
Enablers	Include principles, policies, frameworks, organizational structures, services
Information Flows	Promote accountability and traceability throughout lifecycle

Domains in COBIT 5/2019:

1. **Governance:** Evaluate, Direct, Monitor
2. **Management:** Plan, Build, Run, Monitor

COBIT vs. ITIL – Key Differences

Aspect	COBIT	ITIL
Focus	Governance, compliance, control	Service management, customer-centric delivery
Origin	Developed by ISACA	Created by AXELOS (UK Govt/Capita)
Scope	Strategic control over all IT processes	Operational improvement in IT services (incident, change, etc.)
Structure	Governance framework with control objectives	Library of best practices and service lifecycle stages
Use Case	Used for audit, risk management, compliance	Used for service quality improvement & IT delivery
Certifications	COBIT Foundation, Implementer	ITIL Foundation, Practitioner, Intermediate, Expert
Integration	Often combined with ISO 27001, COSO	Often integrated with ISO 20000 and DevOps

Example:

- A company uses **COBIT** to ensure they follow compliance laws like SOX or GDPR.
- That same company uses **ITIL** to manage user complaints, service requests, or hardware fixes.

What Is HIPAA (Health Insurance Portability and Accountability Act)?

- Enacted in **1996** in the United States
- Designed to:
 - Protect sensitive **health information**
 - Ensure **data portability** across insurance and healthcare entities
 - Set standards for **security and privacy** of medical records
- Applies to:
 - **Healthcare providers**, insurers, clearinghouses
 - Business associates handling **Protected Health Information (PHI)**

HIPAA Regulations

Regulation Area	Description
Privacy Rule	Governs how PHI can be disclosed or accessed
Security Rule	Sets technical safeguards for electronic PHI (ePHI)
Breach Notification Rule	Mandates notification within 60 days of data breach
Enforcement Rule	Defines penalties for non-compliance
Omnibus Rule	Expands accountability to business associates; strengthens individual rights

HIPAA Titles Breakdown

HIPAA is divided into **five titles**, each focusing on different aspects:

Title	Name	Purpose
Title I	Health Care Access, Portability, & Renewability	Protects health insurance coverage when jobs change
Title II	Preventing Health Care Fraud & Abuse	Establishes national standards for e-health care transactions
Title III	Tax-related Health Provisions	Outlines tax rules for medical savings accounts
Title IV	Application & Enforcement of Group Plans	Covers insurance reform for group health plans
Title V	Revenue Offsets	Governs treatment of company-owned life insurance policies

💡 *Most compliance audits focus heavily on Title I and II due to their direct relevance to privacy and security.*

HIPAA Rules – Explained

◆ Privacy Rule

- Protects **individual health records** in any form: paper, digital, verbal
- Grants **patients rights**:
 - Access to their own records
 - Request corrections
 - Limit data sharing

◆ Security Rule

- Focused on **electronic PHI (ePHI)**
- Defines:
 - **Administrative safeguards**: Access controls, staff training
 - **Physical safeguards**: Facility access controls, workstation use
 - **Technical safeguards**: Encryption, authentication protocols

◆ Breach Notification Rule

- Must notify affected individuals and authorities **within 60 days**
- Applies when **unsecured PHI** is exposed or stolen

◆ Enforcement Rule

- Violations can result in **finest from \$100 to \$50,000 per violation**
- Audited by the **Office for Civil Rights (OCR)** under U.S. Department of Health & Human Services

Summary Tips for Revision

- HIPAA protects **medical privacy**, especially **PHI/ePHI**
- Four key rules: **Privacy, Security, Breach Notification, Enforcement**
- Auditors verify HIPAA compliance using interviews, technical assessments, and document reviews
- **Title II + Security Rule** are centerpieces in compliance audits

PCI-DSS

PCI-DSS (Payment Card Industry Data Security Standard)—a critical framework for securing cardholder data and ensuring financial systems are built on trust and protection. 🇪🇺



What Is PCI-DSS?

PCI-DSS is a global security standard designed to protect **credit/debit card transactions** and **sensitive cardholder data**.

◆ Established by:

- **Payment Card Industry Security Standards Council (PCI SSC)** in **2004**
- Founded by major card brands: **Visa, Mastercard, Discover, AMEX, and JCB**

◆ Goal:

- Prevent **fraud, breaches, and data theft** across digital and physical transactions



History of PCI-DSS

Year	Milestone
2004	PCI-DSS v1.0 released—merged standards from major card companies
2006	PCI Security Standards Council (PCI SSC) officially formed
2010–2022	Various updates improve clarity, encryption, and cloud guidance
2022	Release of PCI-DSS v4.0 —focus on flexibility, targeted risk modeling



Modern versions add controls for cloud security, multi-factor authentication, and stronger encryption.



Key Requirements of PCI-DSS

There are **12 core requirements** grouped under 6 broader principles:

Principle	Examples of Requirements
Build and Maintain Secure Networks	Use firewalls; avoid default passwords
Protect Cardholder Data	Encrypt transmission and storage
Maintain Vulnerability Management	Use antivirus; update systems
Implement Strong Access Control	Restrict access based on business need
Monitor and Test Networks	Regular security testing; audit trails
Maintain Info Security Policy	Have a documented, enforced security policy



PCI-DSS Merchant Compliance Levels

These levels are based on **transaction volume** over a 12-month period and dictate the **audit and reporting requirements**.

Level	Annual Transactions	Validation Required
Level 1	Over 6 million card transactions	Annual onsite audit by Qualified Security Assessor (QSA)
Level 2	1–6 million transactions	Self-assessment + quarterly vulnerability scans
Level 3	20,000–1 million e-commerce transactions	Annual self-assessment
Level 4	Fewer than 20,000 transactions	Varies by card brand; basic self-assessment

 *Level 1 merchants handle the most risk and require the most rigorous auditing.*

Why PCI-DSS Matters

- Enhances **consumer trust**
- Avoids **costly data breach penalties**
- Aligns with broader compliance goals like **SOX**, **HIPAA**, and **GDPR**
- Provides a blueprint for **secure transaction systems**

Centre for Internet Security (CIS) Critical Security Controls

Overview

- Developed by **CIS**, a nonprofit organization focused on improving cyber hygiene.
- Known for creating **actionable security controls**, especially the **CIS Top 18 Critical Controls**.
- Based on real-world threats and validated by global security experts.

CIS Controls – Structure & Purpose

Control Group	Examples of Controls	Purpose
Basic (Controls 1–6)	Inventory of assets, access controls, vulnerability management	Establish foundational security
Foundational (7–16)	Email/web browser defenses, data protection, account monitoring	Address common attack vectors
Organizational (17–18)	Incident response, security awareness, penetration testing	Strengthen governance and resilience

💡 *Latest version is CIS Controls v8*—organized around **enterprise functions** rather than legacy tech layers.

✅ CIS Compliance

◆ Goal:

- Help organizations align to best practices for **IT risk reduction**, **audit preparedness**, and **regulatory alignment** (e.g., ISO, NIST, HIPAA, PCI-DSS)

◆ Implementation Tiers:

Tier	Security Maturity
Tier 1	Ad-hoc implementation, limited tracking
Tier 2	Basic controls with partial integration
Tier 3	Fully integrated, measurable security program
Tier 4	Proactive, threat-informed cyber operations

◆ Compliance Benefits:

- **Audit-friendly documentation**
- Faster alignment with **frameworks like NIST CSF, ISO 27001, and SOC2**
- Strengthens **incident response**, **system hardening**, and **policy enforcement**

🔧 CIS Benchmarks

◆ What Are CIS Benchmarks?

- Industry-standard **configuration guidelines** for securing operating systems, cloud platforms, and apps.
- Used by auditors, sysadmins, and red teams to validate system hardening.

Platform	Benchmark Example
Windows OS	Disable guest account, enforce password complexity
Linux	Set audit logging rules, restrict root access
Kubernetes/Docker	Restrict API access, enforce network segmentation
Azure/AWS/GCP	Harden cloud storage, enable multi-factor auth

🔗 What Is the SSE-CMM Project?

- **Full Name:** *Systems Security Engineering Capability Maturity Model*
- **Initiated By:** International Technical Committee under the NSA and IEEE
- **Purpose:** Improve **security engineering processes** in product/system development—not just assess end results
- **Focus:** Practices involved in building secure systems across lifecycle stages

💡 Unlike traditional compliance models, SSE-CMM targets the **engineering behavior and process capability**, not just outcomes or configurations.

History & The Need

Milestone	Details
1993–1996	Developed collaboratively by NSA, NIST, US DoD, Carnegie Mellon SEI
Release of SSE-CMM v2.0	Formalized model published in 1999
Motivation	Lack of consistent methods to build security into system development
Need	Organizations needed a way to benchmark security engineering maturity

◆ Why SSE-CMM Was Needed:

- Traditional audits didn't evaluate **engineering rigor or repeatability**
- Organizations needed:
 - Structured process improvement
 - Early integration of security in design
 - Lifecycle-wide security assurance

SSE-CMM Overview

- Evaluates **Security Engineering processes** against **five maturity levels** (similar to CMM/CMMI)
- Covers **22 Base Practices** under 11 Process Areas including:
 - Configuration Management
 - Risk Management
 - Security Policy Development
 - Education and Awareness
 - Security Requirements Definition

Maturity Levels:

Level	Capability Maturity
1	Initial – Ad hoc & unstructured
2	Repeatable – Some documentation and discipline
3	Defined – Institutionalized across projects
4	Managed – Quantitative management in place
5	Optimizing – Continuous improvement

Using the SSE-CMM

◆ Applications:

- Evaluate **how well security is built into product development**
- Guide **contractual security evaluations** (especially government programs)
- Support **organizational process improvement** initiatives

◆ Process:

1. Select scope (project or organization-wide)
2. Perform a **self-assessment or independent audit**
3. Map existing practices against maturity levels
4. Identify **gaps and improvement strategies**
5. Track changes over time

SSE-CMM Pilots

◆ Early Adopters:

- U.S. Department of Defense
- NASA
- NIST
- Commercial aerospace and telecom firms

◆ Outcome of Pilot Studies:

- Validated that process maturity improves security assurance
- Encouraged integration of SSE-CMM into **CMMI Security Add-on modules**

 *Fun Fact:* SSE-CMM laid the groundwork for future frameworks like **ISO/IEC 21827**—the international standard for security engineering maturity.

Information Technology (Amendment) Act 2008 – ITAA 2008

◆ Overview

- Amendment to the **IT Act 2000**, passed to address evolving cyber threats and data protection needs.
- Introduced provisions for **cybercrime penalties**, **data privacy**, and **electronic governance**.

◆ Key Enhancements

Feature	Details
Data Protection	Sections on reasonable security practices and sensitive personal data
Cybercrime Classification	Defines phishing, identity theft, cyber terrorism, publishing obscene content
Intermediary Liability	Clarifies the responsibility of platforms and service providers
Digital Signature Expansion	Broadened scope of electronic signatures
Adjudication Powers	Granted authority to government officers for hearing cyber offense cases

Digital Personal Data Protection Act 2023 – DPDPA

◆ Purpose

India's first comprehensive data privacy law, passed in **August 2023**, aiming to protect **digital personal data** while enabling lawful processing for service delivery.

◆ Key Principles

1. **Lawful and transparent processing**
2. **Purpose limitation**
3. **Data minimization**
4. **Storage limitation**
5. **Accuracy and integrity**
6. **Security safeguards**
7. **Rights of Data Principals** (individuals)

◆ Compliance Obligations

Entity	Responsibility
Data Fiduciary	Must obtain consent, maintain logs, report breaches
Data Principal	Has rights to correction, access, and erasure of personal data
Consent Managers	Facilitate user-friendly consent collection and withdrawal
Data Protection Board	Adjudicates complaints, enforces penalties

💡 *Fines can range up to ₹250 crore for violations depending on severity.*

Internal Audit Solution – Global Bank

◆ Objective:

- Assess IT and data security posture across APAC operations

◆ Scope:

Domain	Audit Activity
Access Controls	Role-based access matrix, login trails, privileged account monitoring
Regulatory Compliance	SOX, PCI-DSS, GDPR, DPDPA mapping
Incident Handling	Response time analysis, policy alignment
Data Flow Mapping	Ensure encryption at rest and transit
Vendor Risk Management	Evaluate outsourced services for compliance and SLA adherence

◆ Tools Used:

- **GRC Platforms** (e.g., Archer, MetricStream)
- **SIEM systems** for log correlation
- **ISO/COBIT checklists** for gap analysis

Compliance Audit of Anti-Corruption Regulations

◆ Audit Objectives:

- Ensure alignment with **FCPA (Foreign Corrupt Practices Act)** and **PMLA (Prevention of Money Laundering Act)**
- Prevent **bribery, kickbacks, opaque fund movements**

◆ Audit Checklist:

Area	Assessment Focus
Third-Party Due Diligence	Verify background and legal standing
Gifts & Hospitality Logs	Ensure within policy limits
Finance Controls	Forensic accounting, invoice trail integrity
Whistleblower Protections	Check reporting mechanism accessibility & policy
Training Documentation	Ensure anti-corruption training is current and tracked

💡 *Real-world audits often benchmark via ISO 37001: Anti-Bribery Management Systems.*